

PREGUNTA	RESPUESTA
¿Qué técnica de autenticación puede mitigar ataques de reutilización de credenciales conocidas?	Autenticación multi-factor
¿Qué tipo de nube proporciona mayores controles de seguridad?	Privada
¿De acuerdo al estándar de OWASP MASVS: ¿Qué control garantiza que cualquier dato sensible debe estar almacenado en ubicaciones seguras y cifrado?	MASVS-STORAGE (Controles de seguridad de Almacenamiento)
Seleccione 2 ejemplos de errores de configuración, de acuerdo a la categoría de Security Misconfiguration	• Mensajes de error detallados que contienen información confidencial • Aceptar configuraciones predeterminadas que no son seguras
En el modelo de responsabilidad compartida, ¿Qué aspecto de la seguridad en la nube es responsabilidad del cliente?	La gestión de la seguridad de las aplicaciones y datos en la nube
¿Qué práctica brinda al equipo de desarrollo de software una perspectiva similar a la de un atacante o usuario hostil?	Modelado de amenazas
¿Qué se busca al clasificar los riesgos en seguridad informática?	Priorizar los controles basándose en la gravedad de la amenaza
¿Cómo se denomina al proceso de verificación que garantiza que los datos que se proporcionan no se interpretan como código, como es el caso de los ataques de inyección y no se disfraza de formas alternativas que omiten los controles de seguridad?	Sanitización
¿Cómo contribuye la virtualización a la seguridad de los sistemas informáticos?	Permitiendo la consolidación de recursos físicos y facilitando la gestión de la seguridad
¿Cuál de los siguientes consiste en una infraestructura informática en la nube que proporciona recursos de almacenamiento a través de internet?	Infrastructure-as-a-Service (IaaS)
Un _____ es el gestor de tráfico que interactúa con los datos o el servicio backend real y aplica políticas, autenticación y acceso general para las llamadas de una API para proteger datos valiosos	API Gateway
Brinda al equipo de desarrollo de software una perspectiva similar a la de un atacante o usuario hostil, ya que el ejercicio de _____ busca identificar los puntos de entrada y salida que podrían ser explotados por un atacante	Modelado de amenazas
¿Qué ventaja de las aplicaciones Web es también crucial para la seguridad?	Compatibilidad entre diferentes sistemas operativos
Una aplicación RESTFUL debe tener una comunicación cliente servidor sin estado. Esto significa que el contenido de los clientes no se almacena en el servidor entre las solicitudes sino la sesión que queda en el cliente	Verdadero

¿Qué es una función hash en el contexto de la encriptación de datos?	Un algoritmo que convierte los datos en un valor de longitud fija
¿Cuál es una de las razones fundamentales por las que la seguridad en aplicaciones web es crucial en el mundo actual?	La dependencia de las aplicaciones para funciones esenciales como banca en línea y trabajo remoto
¿Qué tipo de comprobación de seguridad se debería de aplicar en la etapa de Codificación de acuerdo a DevSecOps?	Uso de herramientas de pruebas de aplicaciones estáticas (SAST)
¿Cuál es un aspecto clave a considerar en el diseño y desarrollo de aplicaciones Web para garantizar su seguridad?	Implementación de controles de acceso y autenticación robustos
¿Qué aspectos evalúa el modelo DREAD en la clasificación de riesgos?	Daño Potencial, Reproducibilidad, Explotabilidad, Usuarios Afectados, Descubrimiento
Hay muchas amenazas potenciales que pueden ser causadas por una pobre validación de entrada, seleccione 2 de las más comunes	• Inyección SQL • Cross-site scripting (XSS)
Los atacantes prueban sistemáticamente varias combinaciones de claves hasta que encuentran la correcta para descifrar los datos. ¿A qué categoría del OWASP Mobile Top 10 corresponde el ejemplo anterior?	Criptografía insuficiente
El _____ es un software malicioso que inutiliza el dispositivo y encripta la información	Ransomware
De acuerdo al estándar de OWASP MASVS, ¿Qué categoría establece que la aplicación debe validar y desinfectar todas las entradas que no son de confianza?	MASVS-CODE (Controles de seguridad de Código)
¿Cuál es una limitación importante al desarrollar para plataformas móviles en comparación con las computadoras de escritorio?	Menor capacidad de procesamiento y memoria
¿Los anteriores son ejemplos de soluciones ante cuál de las categorías del OWASP API Security Top 10?	Broken Object Level Authorization
Una validación de salida inadecuada puede provocar daños en los datos o vulnerabilidades en la presentación, lo que permite a los malintencionados inyectar código malintencionado o manipular información confidencial que se muestra a los usuarios	Verdadero
La aplicación móvil almacena en cache datos confidenciales como tokens de autenticación de usuario o información de sesión sin implementar las medidas de seguridad adecuadas, si un atacante obtiene acceso a la memoria cache del dispositivo puede obtener esas credenciales y hacerse pasar por el usuario, ¿Qué categoría pertenece del OWASP Mobile Top 10?	Almacenamiento de datos inseguro
¿Cuál es una práctica recomendada para la protección de la consola de gestión en la nube?	Implementar control y supervisión estrictos del acceso con privilegios
¿Cuál es el propósito principal de implementar un WAF (Web Application Firewall) en la seguridad de una aplicación web?	Proteger la aplicación contra vulnerabilidades de seguridad conocidas

¿Cuál de los siguientes es un lenguaje de programación comúnmente utilizado en el desarrollo de aplicaciones móviles?	Swift
La esencia fundamental de la definición del software radica en su capacidad para abordar problemas específicos. Por este motivo, es crucial comprender la naturaleza del problema que se va a resolver antes de su implementación	Verdadero
¿Cuál es una práctica efectiva para mejorar la seguridad en máquinas virtuales?	Implementar plantillas para desplegar máquinas virtuales
El objetivo principal del _____ es educar a los involucrados en el desarrollo y mantenimiento de la API, por ejemplo, desarrolladores, diseñadores arquitectos, gerentes u organizaciones	OWASP API Security Top 10
¿Qué garantiza la compatibilidad de las aplicaciones web en diferentes plataformas?	El lenguaje HTML utilizado en los navegadores
¿Cuál de las siguientes opciones representa una práctica efectiva para manejar componentes vulnerables y desactualizados en aplicaciones?	Realizar un inventario regular de componentes y sus dependencias
¿Cómo se deben proteger las claves SSH de API en un entorno de nube?	Eliminándolas del código fuente y asegurando el acceso solo a aplicaciones autorizadas
En el contexto de la seguridad de aplicaciones web, ¿qué implica un ataque de 'inyección'?	Envío de comandos no autorizados a través de una aplicación web
Monitorear y registrar el acceso a flujos comerciales para detectar y responder actividades no autorizadas.... ¿Los ejemplos proporcionados son soluciones ante cuál de las categorías del OWASP API Security Top 10?	Unrestricted Access to Sensitive Business Flows
¿Cómo se denomina al proceso de evaluar los controles de seguridad de la información e implementar el proceso y las herramientas correctas en los sistemas de TI para proteger los datos que utiliza y almacena una organización?	Modelado de amenazas
¿Cuál de las siguientes afirmaciones describe mejor la diferencia entre el Análisis Estático de Aplicaciones de Seguridad (SAST) y el Análisis Dinámico de Aplicaciones de Seguridad (DAST)?	SAST inspecciona el código sin ejecutarlo, mientras que DAST inspecciona el código durante su ejecución
¿Cuáles de las siguientes son estrategias válidas para prevenir amenazas de tipo inyección?	• Implemente validaciones de entradas de datos en el servidor, utilizando "listas blancas" • Se requiere separar los datos de los comandos y las consultas
¿Cuál es una práctica efectiva para la seguridad en máquinas virtuales?	Implementar las mismas medidas de seguridad que en un entorno físico
Siempre utilice la última versión de software de gestión de bases de datos y aplique todos los parches tan pronto. ¿El anterior es un ejemplo de mejor práctica de seguridad de base de datos, ¿de qué	Seguridad del software de base de datos

categoría?	
¿Cuál es un reto principal en la seguridad del cloud computing?	La gestión de múltiples proveedores de servicios en la nube
¿Qué estrategia es efectiva para minimizar los riesgos de seguridad en máquinas virtuales?	Implementar las mismas medidas de seguridad en las máquinas virtuales que en los sistemas físicos
Las debilidades en la lógica de las aplicaciones no se limitan a fallos en la implementación por parte de los desarrolladores. Estas surgen cuando la aplicación responde de manera inesperada ante desviaciones del comportamiento estándar de una función, ya sea originadas por un usuario convencional o un agente con intenciones maliciosas.	Verdadero
¿Qué es una auditoría de seguridad en el contexto de TI?	La evaluación sistemática de la efectividad de las medidas de seguridad
Sin las limitaciones adecuadas los atacantes pueden saturar las API enviando varias solicitudes. Esto conduce a la degradación de los servicios, ataques DOS / DDOS, problemas de latencia de rendimiento, bloqueos, etc. ¿A qué categoría del OWASP API Security Top 10 hace referencia el enunciado anterior?	Unrestricted Resource Consumption
Se pueden establecer reglas _____ para bloquear patrones de solicitud y respuesta hacia las API que apunten hacia posibles vulnerabilidades.	WAF
¿Cuál es una práctica recomendada para proteger las consolas y herramientas de administración de DevOps en la nube?	Controlar y supervisar estrictamente el acceso a estas herramientas y consolas
Un juego móvil puede publicar su aplicación y los primeros niveles de forma gratuita. Si a los usuarios les gusta el juego, pagan por el acceso completo. Todos los recursos para los niveles posteriores se envían con la aplicación. Solo están protegidos por una verificación de licencia, donde la licencia se descarga cuando el usuario paga. Un atacante podría aplicar ingeniería inversa a la aplicación e intentar comprender cómo se realiza la verificación del pago. Podría ser fácil localizar la comprobación de licencia y simplemente reemplazarla con una declaración de éxito estática. El atacante puede volver a compilar la aplicación y jugarla gratis o incluso venderla con otro nombre en las tiendas de aplicaciones ¿A que categoría del OWASP Mobile Top 10 corresponde el ejemplo anterior?	Protección binaria insuficiente
¿Qué proyecto de OWASP ofrece diez puntos para planificar e implementar un entorno seguro de contenedores?	OWASP Docker Top 10
¿Cuáles de las siguientes son estrategias válidas para prevenir amenazas de tipo Cryptographic Failures? Seleccione 3	• Asegurarse de encriptar todos los datos sensibles • No almacene datos sensibles innecesariamente

	• Cifre todos los datos en tránsito con protocolos seguros como TLS
La criptografía NO juega un papel especialmente importante en la seguridad de los datos del usuario, más aún en un entorno móvil, donde los atacantes que tienen acceso físico al dispositivo del usuario es un escenario probable	Falso
El código de JavaScript de cliente se debe ejecutar mediante el uso de un _____ con lo que todo lo malicioso que se intente ejecutar queda aislado y sin acceso a los recursos de interés de la máquina atacada	Sandbox
De acuerdo al estándar de OWASP MASVS, ¿qué categoría establece que la aplicación móvil debe realizar conexiones seguras bajo cualquier circunstancia?	MASVS-NETWORK (Controles de seguridad de Red)
Deshabilite características, servicios o módulos innecesarios que no son necesarios para la funcionalidad de la API. Implementar mecanismos adecuados de manejo de errores y registro para evitar que la información confidencial se exponga en los mensajes de error ¿Los anteriores son ejemplos de soluciones ante cuál de las categorías del OWASP API Security Top 10?	Security Misconfiguration
¿Cuáles serían las tareas de seguridad en la etapa de pruebas de verificación y validación?	Análisis dinámico sobre la aplicación y revisiones de código
En el contexto de seguridad de contenedores ¿Cuál es la importancia de utilizar un registro privado?	Proporciona control de acceso basado en roles y ayuda a rastrear vulnerabilidades
¿Qué término describe el proceso de transformar algo originalmente considerado peligroso en una forma inofensiva para la aplicación o sistema?	Sanitización
¿Qué consecuencia puede derivarse de una mala gestión de credenciales en aplicaciones móviles?	Acceso no autorizado a datos confidenciales
Las _____ en las API se producen cuando las prácticas recomendadas de seguridad no se siguen correctamente o la seguridad de la pila de API no se refuerza correctamente. Algunos ejemplos de esta vulnerabilidad incluyen los últimos parches no aplicados, la exposición no deseada de registros de depuración, opciones heredadas sin parches, características/servicios innecesarios, implementación incorrecta de la política CORS, verbos HTTP habilitados innecesarios, etc.	Security Misconfiguration
¿Cuál de las siguientes es una forma de evitar amenazas de tipo Identification and Authentication Failures?	Limite o incremente el tiempo de espera entre intentos fallidos de inicio de sesión
El Estándar de Verificación de Seguridad de Aplicaciones Móviles (MASVS) de OWASP define un modelo de seguridad de aplicaciones móviles y enumera los requisitos de seguridad genéricos para aplicaciones móviles	Verdadero
¿Cuáles de las siguientes son estrategias válidas para prevenir	• Denegar accesos por defecto

amenazas de tipo Broken Access Control? Seleccione 3	• Control de acceso a nivel de datos • Establecer límites de acceso a las APIs
¿Qué categoría de las OWASP Top 10 de 2021 ahora ocupa el primer lugar, desplazando a la categoría que dominó en ediciones anteriores?	A01:2021 - Broken Access Control
El formato preferido para los mensajes de REST APIs es _____, ya que, a pesar de su nombre, puede leerlo cualquier lenguaje de programación, es ligero y lo comprenden tanto las personas como las máquinas	JSON
¿Qué método de análisis de código necesita un entorno simulado que reproduzca las condiciones del entorno de producción donde se desplegará el código?	Análisis de código dinámico
En el contexto de componentes vulnerables y desactualizados, ¿qué herramienta es recomendada para supervisar continuamente fuentes como CVE y NVD?	Security Information and Event Management (SIEM)
Se refiere a medidas como la instalación de barreras en los perímetros de los centros de datos, el uso de cerraduras, la presencia de guardias de seguridad, tarjetas de acceso a sistemas biométricos de control, cámaras de vigilancia y sensores de detección de intrusos	Controles de seguridad física
Seleccione 3 estrategias que podemos implementar para evitar amenazas del tipo Software y Data Integrity Failures	• Asegúrese que datos sin cifrar o firmar no son enviados a clientes no confiables • Utilice firmas digitales o mecanismos similares para verificar el software o datos • Asegúrese que se utilice un proceso de revisión de cambios de código
En la seguridad en la nube, ¿qué práctica es fundamental para proteger las cuentas de administración SaaS?	Controlar y supervisar estrictamente los privilegios de acceso a la consola de administración SaaS
En el contexto de la seguridad en la nube, ¿cómo se deben manejar las claves SSH de API?	Eliminarlas del código fuente y asegurando el acceso solo a aplicaciones autorizadas
¿Cuál es el propósito principal de identificar límites de confianza en la identificación de amenazas?	Identificar qué acciones o comportamientos del software son permitidos o no
¿Cuál es una responsabilidad clave del cliente en el modelo de responsabilidad compartida para la seguridad en la nube?	Gestionar la seguridad de las aplicaciones y datos alojados en la nube
Demasiadas peticiones dirigidas a una API pueden ralentizar o detener el servicio para otros clientes. ¿A qué tipo de amenaza hace referencia el enunciado anterior?	Ataques DoS y DDoS
¿Qué estrategia es esencial para garantizar la seguridad de las máquinas virtuales?	Implementar todos los controles de seguridad, como en un entorno físico
¿Cuál de los siguientes NO representa un área crítica de la superficie de ataque móvil de acuerdo con OWASP MASVS?	MASVS-DevOps (Controles de seguridad de DevOps)

Al emplear contenedores, la implementación de un _____ posibilita la gestión del acceso mediante asignaciones de roles, al tiempo que facilita la administración del contenido mediante la asignación de metadatos específicos al contenedor	Registro privado
¿Cuál de las siguientes debilidades puede resultar en fallas de identificación y autenticación?	Permitir contraseñas por defecto débiles
Puede haber debilidades de autenticación si la aplicación no posee una autenticación multi-factor	Verdadero
¿Cuál es el término que describe la acción de un agente que provoca intencionalmente que una amenaza se materialice?	Ataque
De acuerdo con el estándar de OWASP MASVS, ¿Qué categoría está diseñada para ayudar a los desarrolladores a garantizar que los datos confidenciales almacenados intencionalmente por la aplicación estén protegidos adecuadamente, independientemente de la ubicación de destino?	MASVS-STORAGE (Controles de seguridad de Almacenamiento)
¿Cómo podemos prevenir amenazas de tipo Security Misconfiguration? Seleccione 2 opciones	• Elimine o no instale características y frameworks no utilizados • Un proceso automatizado para verificar la efectividad de las configuraciones y ajustes en todos los entornos
La _____ se produce cuando las API procesan solicitudes de direcciones URL controladas por el usuario y obtienen recursos internos o remotos del servidor sin validar primero la solicitud del usuario	Server-Side Request Forgery
¿Qué método se utiliza para examinar los requisitos de seguridad en todas las etapas de creación del software, abarcando desde análisis hasta mantenimiento, garantizando su integración en cada fase del proceso de desarrollo?	S-SDLC
De acuerdo al estándar de OWASP MASVS. ¿Qué categoría establece controles que cubren el uso seguro de los mecanismos IPC proporcionados por la plataforma, las configuraciones de WebView para evitar la fuga de datos confidenciales y la exposición a la funcionalidad, y la visualización segura de datos confidenciales en la interfaz de usuario de la aplicación?	MASVS-PLATFORM (Controles de seguridad de Plataforma)
¿Qué es la criptografía asimétrica?	Una técnica de cifrado que usa claves diferentes para cifrar y descifrar datos
En el modelo de responsabilidad compartida en la seguridad en la nube. ¿qué es responsabilidad del proveedor de servicios en la nube?	Proteger la infraestructura subyacente como servicios de almacenamiento y redes.
¿Cuál es un principio clave en la seguridad del desarrollo de software?	La revisión periódica del código por pares
¿Cuál de los siguientes elementos es utilizado para la Integración de	API

sistemas y la creación de aplicaciones Interconectadas?	
¿Qué práctica es crucial para proteger la consola de gestión en la nube?	Supervisar y controlar estrictamente el acceso a la consola de gestión en la nube
Para realizar un ataque SSRF, un atacante puede cambiar el valor de un parámetro en la aplicación web vulnerable para usar las peticiones predeterminadas desde el servidor vulnerable	Verdadero
¿Cuál de las siguientes es una de las mejores prácticas recomendadas para asegurar la seguridad de una base de datos?	Utilizar la última versión del software de gestión de bases de datos y aplicar todos los parches de seguridad
De acuerdo al estándar de OWASP MASVS ¿Qué categoría establece que la aplicación debe contar con un mecanismo para hacer cumplir las actualizaciones de la aplicación?	MASVS-RESILIENCE (Controles de seguridad de resiliencia)
¿Cuál es una ventaja clave del Análisis de Código Estático (SAST) en comparación con el Análisis de Código Dinámico (DAST)?	SAST puede detectar errores y vulnerabilidades en una etapa temprana del desarrollo de software
En la seguridad en la nube, ¿cómo se deben proteger las claves SSH de API?	Eliminarlas del código fuente y asegurar que solo aplicaciones autorizadas tengan acceso
¿Cuál de las siguientes opciones representa una situación que un atacante podría aprovechar para comprometer la seguridad?	Vulnerabilidad
¿Qué estrategia es recomendada para asegurar la Integridad de las bibliotecas y dependencias en proyectos de alto riesgo?	Alojar las bibliotecas en un repositorio interno previamente analizado
¿Qué tipo de comprobación de seguridad se debería de aplicar en la etapa de Deployment de un pipeline de acuerdo a DevSecOps?	Uso de herramientas de pruebas dinámicas de seguridad de aplicaciones
Es crucial considerar cuidadosamente los flujos de negocio que exponen un punto de enlace de API, ya que algunos flujos contienen información más confidencial que podría causar un daño significativo si se accede sin las restricciones adecuadas. ¿A qué categoría del OWASP API Security Top 10 hace referencia el enunciado anterior?	Unrestricted Access to Sensitive Business Flows
¿Cuál de las siguientes opciones representa una práctica efectiva para manejar componentes vulnerables y desactualizados en aplicaciones web?	Realizar un inventario regular de componentes y sus dependencias
¿Cuál de las siguientes es una medida de seguridad eficaz para proteger aplicaciones web contra vulnerabilidades comunes?	Uso de un cortafuegos de aplicaciones web (WAF)
¿Cuál es un riesgo asociado con la seguridad inadecuada de la cadena de suministro en aplicaciones móviles?	Inserción de malware durante el desarrollo
¿Cuál de las siguientes prácticas permite a los equipos de DevOps crear y versionar rápidamente la Infraestructura de la misma manera que versionan el código fuente y realizar un seguimiento de estas versiones para evitar Inconsistencias entre los entornos de TI que pueden provocar problemas graves durante la Implementación?	Infrastructure-as-Code (IaC)

¿Cuál de las siguientes opciones representa un protocolo estándar inicialmente creado para facilitar la comunicación entre aplicaciones desarrolladas en diversos lenguajes y plataformas diferentes?	SOAP
Un diseño Inseguro no puede ser solucionado únicamente con una implementación perfecta, ya que, por su naturaleza, carece de los controles de seguridad necesaria para protegerse de ataques específicos	Verdadero
Implementar la validación y el filtrado de URL para bloquear o desinfectar URL potencialmente maliciosas. Monitorear y registrar solicitudes del lado del servidor para detectar e investigar cualquier actividad sospechosa o no autorizada. ¿Los anteriores son ejemplos de soluciones ante cuál de las categorías del OWASP API Security Top 10?	Server Side Request Forgery (SSRF)
De acuerdo al estándar de OWASP MASVS ¿Qué control garantiza que cualquier dato sensible debe de estar almacenado en ubicaciones privadas?	MASVS-STORAGE (Controles de seguridad de Almacenamiento)
¿Qué categoría de las OWASP Top 10 de 2021, ahora ocupa el primer lugar, desplazando a la categoría de Inyección que dominó en ediciones anteriores?	A01:2021 - Broken Access Control
El _____ se dirige a una persona concreta para robar sus datos, ya se trate de credenciales de acceso a sistemas o de números de tarjetas de crédito. Por lo general, el ciberdelincuente se hace pasar por una persona o empresa de confianza	Phishing
En el contexto de Docker. ¿qué práctica aumenta la seguridad de los contenedores?	Utilizar registros con certificados válidos o TLS
Lista blanca de URL o direcciones IP permitidas para restringir los destinos de las solicitudes del lado del servidor. Utilice bibliotecas o funciones de análisis de URL que impongan una validación estricta y solo permitan URL válidas. ¿Los anteriores son ejemplos de soluciones ante cuál de las categorías del OWASP API Security Top 10?	Server Side Request Forgery (SSRF)
Una aplicación móvil se lanza con la configuración predeterminada que tiene habilitadas las configuraciones de seguridad débiles. Esto incluye el uso de protocolos de comunicación inseguros, dejar los nombres de usuario y contraseñas predeterminados sin cambios y no deshabilitar las características de depuración en las compilaciones de la versión ¿A que categoría del OWASP Mobile Top 10 corresponde el ejemplo anterior?	Configuración incorrecta de seguridad